

## Tema 10

### Răspunsuri la incidentele de securitate cibernetică

#### *Scenariul nr. 1 – Întreruperea neașteptată a rețelei*

 Algoritm de acțiune:

##### 1. Colectarea informațiilor

- Contactez fiecare departament afectat și notez detaliile exacte ale problemei (momentul apariției, durata, simptome specifice, impact asupra activității).
- Consult administratorii de sistem și echipa IT pentru a vedea dacă s-au efectuat modificări recente în infrastructură.
- Verific logurile de evenimente ale serverelor, firewall-urilor și echipamentelor de rețea pentru a detecta anomalii sau erori repetate.
- Efectuez un test de conectivitate prin ping și traceroute pentru a localiza punctele de eșec și pentru a verifica latențele neobișnuite.
- Utilizez un sistem de monitorizare a traficului de rețea (ex. Wireshark, Nagios, Zabbix) pentru a identifica fluxurile de date suspecte sau congestiile anormale.

##### 2. Identificarea cauzei

- Analizez încărcarea traficului din rețea pentru a verifica dacă există o congestie cauzată de procese interne sau de atacuri externe, cum ar fi DDoS.
- Examinez configurările DHCP și DNS pentru a mă asigura că serviciile esențiale sunt funcționale și că nu există modificări neautorizate.
- Compar logurile de rețea cu incidentele anterioare pentru a detecta tipare de probleme recurente, cum ar fi erori frecvente de routing sau pierderi de pachete.
- Dacă problema este software, investighez dacă un update recent a cauzat instabilitate și analizez compatibilitatea acestuia cu infrastructura existentă.
- Verific integritatea echipamentelor hardware pentru a detecta defecțiuni fizice care ar putea afecta conexiunile de rețea.

##### 3. Soluționarea problemei

- Dacă un dispozitiv de rețea a eșuat, îl repornesc sau îl înlocuiesc cu unul de rezervă, asigurând redundanță pentru echipamente critice.
- În cazul unei erori software, revin la ultima configurație stabilă și efectuez rollback-ul update-urilor problematice.
- Dacă problema este un atac DDoS, activez mecanismele de protecție precum rate limiting, geo-blocking și filtre automate pentru a bloca IP-urile suspecte.

- Ajustez și aplic reguli de firewall mai stricte pentru a limita accesul neautorizat la rețea.
- Dacă problema este legată de congestie internă, optimizez rutele de trafic și prioritizez serviciile critice utilizând QoS (Quality of Service).

#### 4. Verificarea funcționalității

- Confirm cu fiecare departament afectat că și-au recăpătat accesul normal la rețea și că funcționalitatea sistemelor este restaurată.
- Continui monitorizarea traficului pentru a detecta eventuale probleme recurente și pentru a evalua performanța rețelei după aplicarea soluțiilor.
- Documentez incidentul, cauzele identificate și soluțiile aplicate pentru referințe viitoare și pentru îmbunătățirea procedurilor de intervenție.

#### Concluzii și recomandări:

- Implementarea unui sistem de monitorizare continuă a rețelei care să alerteze în timp real asupra problemelor și să permită intervenții rapide.
- Crearea unor proceduri de răspuns rapid la incidente pentru echipa IT, inclusiv simulări regulate ale diferitelor scenarii de avarie.
- Stabilirea unui plan de backup și redundanță pentru infrastructura de rețea, astfel încât să existe alternative în caz de defecțiuni critice.

### *Scenariul nr. 2 – Atac de tip phishing și software malițios*

#### Algoritmul de acțiuni:

##### 1. Izolarea amenințării

- Identific dispozitivele infectate prin scanarea rețelei și izolarea acestora de infrastructura principală pentru a preveni răspândirea malware-ului.
- Dezactivez imediat conturile compromise și resetez parolele utilizatorilor afectați, activând autentificarea multi-factor pentru securitate suplimentară.
- Blochez domeniile de phishing identificate și adresele IP suspecte din firewall pentru a preveni atacuri ulterioare.
- Opresc activitatea serverelor care au fost infectate și inițiez o analiză detaliată asupra sursei malware-ului.

## 2. Analiza daunelor

- Analizez logurile de acces și e-mail pentru a identifica sursa inițială a atacului și conturile afectate.
- Utilizez un sandbox pentru a examina comportamentul malware-ului în mediu izolat și pentru a identifica indicatorii de compromitere (IoCs).
- Verific dacă datele confidențiale au fost exfiltrate sau criptate de ransomware și dacă există cereri de răscumpărare.
- Colaborez cu echipa de securitate și furnizorii de securitate cibernetică pentru a găsi soluțiile optime de remediere.

## 3. Restabilirea securității

- Șterg și reinstalez sistemele afectate din backup-uri sigure.
- Aplic patch-uri de securitate și actualizări pentru a preveni reapariția vulnerabilității exploatare.
- Configurez politici de restricție pentru a limita execuția fișierelor necunoscute.

## 4. Prevenirea atacurilor viitoare

- Organizez sesiuni de training pentru angajați cu simulări de phishing regulate.
- Îmbunătățesc politicile de filtrare a e-mailurilor și implementez scanere anti-malware mai eficiente.
- Instalez soluții EDR (Endpoint Detection and Response) pentru monitorizarea continuă a activității neobișnuite.

## Concluzii și recomandări:

- Dezvoltarea unei mentalități de securitate cibernetică prin instruirea periodică a angajaților privind metodele actuale de phishing.
- Implementarea unui plan de răspuns la incidente care include proceduri clare pentru izolarea și remedierea rapidă a unui atac.
- Utilizarea unui sistem avansat de threat intelligence pentru identificarea proactivă a amenințărilor emergente.

### *Scenariul nr. 3 – Acces neautorizat la date confidențiale*

## Algoritm de acțiune:

### 1. Detectarea amenințării

- Monitorizez logurile de acces pentru activități suspecte și verific utilizatorii care încearcă să acceseze date sensibile în afara orelor de program.

- Utilizez un sistem SIEM (Security Information and Event Management) pentru detectarea comportamentelor anormale și analizarea corelațiilor dintre evenimente.
- Analizez modificările de permisiuni și transferurile de date către dispozitive externe sau cloud nesecurizat.
- Aplic politici stricte de control al accesului pe baza principiului minimului privilegiu.

## 2. Răspuns și prevenire

- Blochez accesul utilizatorului suspect și inițiez o investigație amănunțită.
- Implementez autentificarea multi-factor pentru datele sensibile.
- Organizez sesiuni de training pentru angajați privind protecția datelor.

## Concluzii și recomandări:

- Aplicarea măsurilor de securitate bazate pe accesul minim necesar.
- Monitorizarea activă a accesului la date și implementarea alertelor automate.
- Crearea unui protocol de raportare a incidentelor de securitate.